ICS 35.240
CCS L77

YD

中华人民共和国通信行业标准

YD/T [×××××]—[××××]
[代替 YD/T]

开源项目选型参考框架

Open source project selection framework

[点击此处添加与国际标准一致性程度的标识]

（报批稿）

[点击此处添加本稿完成日期]

[××××]-[××]-[××]发布　　[××××]-[××]-[××]实施

中华人民共和国工业和信息化部　发　布

目　　次

前　　言 II
引　　言 III
1 范围 1
2 规范性引用文件 1
3 术语和定义 1
4 许可证合规性 2
4.1 项目许可证规范性 2
4.2 组件许可证规范性 2
4.3 许可证兼容规范性 2
5 软件安全性 2
5.1 安全漏洞修复 2
5.2 安全保障机制 2
6 软件活跃度 3
6.1 项目活跃度 3
6.2 社区活跃度 3
6.3 贡献活跃度 3
7 技术成熟度 3
7.1 软件质量 3
7.2 版本成熟度 3
7.3 应用成熟度（可选） 3
7.4 生态健康度 3
8 服务支持力 3
8.1 项目持续性 3
8.2 问题解答效率 3
8.3 文档完备性 4
8.4 商业支持（可选） 4
9 软件兼容性 4
9.1 版本兼容 4
9.2 运行环境兼容 4
参 考 文 献 5

前　言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》给出的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别这些专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院、深圳市腾讯计算机系统有限公司、华为技术有限公司、中兴通讯股份有限公司、普元信息技术股份有限公司。

本文件主要起草人：栗蔚、郭雪、武倩聿、张一阳、杨晓光、谭燕齐、王玉茂、项曙明、李响、孟庆余、邓通。

引　言

近几年开源技术快速发展，在云计算、移动互联网、大数据等领域逐渐形成技术主流。开源一方面可以突破技术壁垒，推动技术创新，另一方面，不可避免的带来开源管理、开源合规等一系列问题。

本文件针对开源发起方对开源项目的审核和支持不完善等问题，制定了开源项目在许可证合规性、软件安全性、软件活跃度、技术成熟度、服务支持力和软件兼容性六个方面应遵循的规范，对每项的实现方式不作规定。

开源项目选型参考框架

1 范围

本文件规定了开源项目在许可证合规性、软件安全性、软件活跃度、技术成熟度、服务支持力和软件兼容性共六个方面需要遵循的规范。

本文件适用于开源项目发起方对项目的规范性、安全性、兼容性、活跃度、成熟度、支持度进行评估，帮助其规范开源项目管理，并为开源项目使用方提供选型参考依据。

2 规范性引用文件

下列文件对于本文件的应用是必不可少的。凡是注日期的引用文件，仅所注日期的版本适用于本文件。凡是不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 15532-2008 计算机软件测试规范

3 术语和定义

下列术语及定义适用于本文件

3.1

开源 open source

开放一类技术或一种产品的源代码、源数据、源资产，可以是各行业的技术或产品。

3.2

开源软件 open source software

允许用户直接访问源代码，通过开源许可证将其复制、修改、再发布的权利向公众开放的计算机软件。

3.3

开源许可证 open source license

开源软件的版权持有人通过该类许可证，授予用户可以学习、使用、修改开源软件，并向任何人或为任何目的分发开源软件的权利。

4 缩略语

下列缩略语适用于本文件：

API：应用程序接口（Application Programming Interface）

CLA ：贡献者许可协议（Contribution License Agreement）

OSI： 开放源码促进会（Open Source Initiative）

5 许可证合规性

5.1 项目许可证规范性

应对开源源代码的使用、复制、修改和再发布等进行限制。应在软件源代码或附加文件中声明所使用的开源许可证名称，优先使用经开放源码促进会（OSI）认可、业界广泛使用、对专利权有明确说明的许可证类型。

项目许可证内容应包括但不限于：

a） 是否保留版权；

b） 是否授予专利权；

c） 开源软件作者或版权持有人进行署名；

d） 明确开源许可证名称，保留许可证全文或链接；

e） 是否允许商业使用；

f） 是否允许修改及修改后再发布；

g） 是否允许私人使用；

h） 明确开源软件的作者或版权持有人不承担软件使用后的风险及产生的后果。

5.2 组件许可证规范性

应通过代码扫描等方式确认项目所含开源组件及许可证情况，对所有引用的第三方组件进行说明。确保引入的所有开源组件满足开源许可证的合规要求，且正确履行开源使用声明义务，如：

a） 许可证覆盖率；

b） 使用的许可证是否为开放源码促进会（OSI）认可。

5.3 许可证兼容规范性

应明确开源项目的各个组件之间、组件与项目之间的许可证兼容性，解决可能存在的许可证条款冲突。

6 软件安全性

6.1 安全漏洞修复

根据实际情况有针对性的发布安全补丁或更新版本，并在新版本发布时说明漏洞或缺陷的修复情况。

6.2 安全保障机制

建立社区公开沟通途径，设置安全团队或安全人员，定期跟踪社区提问反馈情况并及时修复安全漏洞等问题。

7 软件活跃度

7.1 项目活跃度

应定期发布新版本，并在每一次版本更新时说明所迭代的功能或修补的漏洞情况。

7.2 社区活跃度

应通过代码托管平台等途径，以项目为核心建立开源社区，并及时与参与者进行沟通，维持社区活跃度。

示例：代码托管平台的关注、提问、拷贝、邮件量等数据。

7.3 贡献活跃度

应通过代码托管平台等途径，以项目为核心建立个人/企业的开发者贡献机制，提供公开的贡献说明文档和贡献者许可协议，积极吸纳外部开发者贡献。例：代码托管平台的贡献者数目、提交代码次数等数据。

8 技术成熟度

8.1 软件质量

应具备软件质量检查机制，在代码编写、数据格式等方面遵循业内标准；每个版本发布前需进行测试且测试覆盖度满足业内规范，确认软件符合规范方可发布。

注：软件测试过程中，除满足上述要求，还应满足GB/T 15532-2008中的要求。

8.2 版本成熟度

应至少已发布一个稳定版本，并具备明确的补丁发布策略，能够定期发布补丁包。

8.3 应用成熟度（可选）

应具备至少 1 个以上国内大型企业用户或 3 个以上国内中小型企业用户的应用案例，在第三方公开平台或已发布报告的同类项目排名中占据领先位置。

8.4 生态健康度

项目主要贡献者来自不同国家的多个企业或组织，社区组成多元化；项目能够支持与多种其他软件集成使用。

9 服务支持力

9.1 项目持续性

应明确开源项目是否在开源基金会下孵化或托管，是否在多个不同的代码托管平台上有备份。

9.2 问题解答效率

应设置负责人定期跟进社区情况，及时回复反馈社区中提出的问题。

9.3 文档完备性

应具备完备的项目说明文档，包含项目设计说明、API接口信息、安装部署指南等信息。

9.4 商业支持（可选）

应具备付费的企业版本，或能够由第三方公司提供本地化的设计开发、运维支持、培训等服务。

10 软件兼容性

10.1 版本兼容

应遵循语义化版本号规范，同时保证项目所发布新版本的软件接口能够与以往发布的旧版本兼容。

10.2 运行环境兼容

应能够在不同的硬件架构、网络、操作系统中正常运行，兼容多种数据格式，并在不同数据库、浏览器等配合环境中运行应得到一致的运行结果。

参 考 文 献

[1] 《统计上大中小微型企业划分办法(2017)》